Central City

SECURITY REVIEW

Central City Security Audit

October 2026, version 1.1

PREPARED FOR

Central City users and integrators

PREPARED BY

Central City Audit Division

Version	v1.1
Report date	27 October 2026
Reviewed code	Central City app, main branch at c7ef7583d469 (25 Oct 2026)
Contracts	Fee routers 1 to 3 at central-city b937f787220b, 5dd0d2cdcc52 and 01d1f58a8de4; Central City's own paymaster at 0x8Bf5b18b733a864c17Cd92615cD45D833Fcfe105, deployed from the upstream verifying-paymaster release v1.0.0 (ca356bb0ff67)
Network	Base mainnet (chain id 8453)
Report commit	88e7aab8b090

Version 1.1, 27 October 2026. Supersedes version 1.0 of 26 October 2026.
This report was written by the team that builds and runs Central City. It covers the listed code and addresses at the listed time only. Report a security problem to security@centralcity.ai; questions about this review to hello@centralcity.ai.

This is an internal review by the team that builds Central City. It is not an independent third-party audit and it is no guarantee. It covers the smart contracts and the off-chain payment services around them, at the versions and addresses listed in this report.

Contents

1. About this review 4
2. Scope 6
3. Method 11
4. Summary of findings 13
5. Findings 14
CCA-731: A re-signed router 3 purchase could be paid twice 14
CCA-732: A flood of cheap fee events could stall the fee ledger 14
CCA-733: Router 2 and 3 addresses came from configuration on mainnet 15
CCA-734: The sponsored first purchase skipped the payment engine's pre-send checks 15
CCA-735: A batch member could be marked never sent after its batch was broadcast 16
CCA-738: A correct router 3 payment submitted by someone else is recorded as an anomaly 17
CCA-739: A router 3 authorization used long before the check can leave a call pending 17
CCA-763: Verify simulations had no shared budget during a rate-limiter outage 18
CCA-766: Many payers can use up the public settlement daily cap 18
CCA-744: Failing or front-run batch members can waste facilitator gas, within a bound 19
CCA-748: No deploy record for the paymaster, and a wrong licence label for router 3 19
CCA-750: Preparing the same operation twice in one second holds budget 20
CCA-752: Sponsored operations that revert are still paid from the deposit 20
CCA-756: Screening reuses decisions and relies on an oracle without verified source 21
6. What we verified 22
7. Earlier internal reviews 23
8. Known limits and out of scope 32
9. Recommendations 33

10. Report a problem 34

1. About this review

The Central City Audit Division reviewed the parts of Central City that move money and have public source code or a public address on Base, at the depth stated for each in Scope. Some money paths in the app were checked only through the findings of the earlier internal reviews (see Scope and Known limits). A separate internal security reviewer signs off every finding and every exact version of this report.

- **When:** 16 to 26 October 2026. The internal reviews of 15 and 16 October 2026 are carried forward (see Earlier internal reviews).
- **What:** the smart contracts, their on-chain powers, and the off-chain payment services around them (see Scope).
- **How:** manual review, tests and exploit attempts on local forks of Base only, and read-only analysis of the chain (see Method).
- **Rules we kept:** the review's own inspection and testing were read-only on production and on chain, and its exploit tests ran only on local copies of the chain; it made no transaction, approval or key rotation. The fixes were made separately, as remediation: each was reviewed and approved by the security gate before it was deployed. This report is published only with the owner's approval of the final version.

In short:

- **New findings in the listed contract review were Low or Info; carried-forward findings retain their stated severities and statuses.** For the contracts at the addresses and versions listed in Scope, as reviewed in October 2026: fee routers 1 to 3 have no admin powers, their code on chain is byte-identical to the reviewed source, the fee math is exact, and they move only the payer's own funds, once per payer and reference on each router. Central City runs its own paymaster (the VerifyingPaymaster at 0x8Bf5b18b733a864c17Cd92615cD45D833Fcfe105 in Scope), deployed from unmodified upstream code; Coinbase's paymaster is kept as a backup. The contract review's fixed findings are listed in Findings, each with its own severity (see also What we verified). This is a point-in-time result for those versions, not a guarantee.
- **What this version lists.** The findings whose fixes are in production, all of them fixed: 14 new findings (9 Low and 5 Info) and 183 findings of the earlier internal reviews (28 Medium, 117 Low and 38 Info). Each fix was either verified by a reviewer who did not write it or approved as fixed by the owner after a team review.

Notices

- **Version:** 1.1, 27 October 2026. Supersedes version 1.0 of 26 October 2026.
- **Public version:** this version presents the findings that are fixed in production and suitable for public disclosure; it is not a complete reproduction of the restricted internal register. Every count and total in this report covers the findings in this publication only.
- **Internal review:** this is not an independent third-party audit.
- **Conflict of interest:** the authors of this report build and run the system it reviews.
- **Point in time:** the review was time-boxed. It reflects the listed commits and addresses at the time of review only, and later changes are not covered.
- **No guarantee:** this report does not guarantee that the system is free of vulnerabilities. It is not investment, legal or financial advice.

Revision history

Version	Date	Change
v1.0	2026-10-26	Version 1.0.
v1.1	2026-10-27	Lists the findings fixed in production, with their status (see Notices). Supersedes version 1.0.

2. Scope

Smart contracts

Contract	Address on BaseScan	Deploy transaction	Source commit	Owner or admin	Upgradeable	Bytecode matches source
CentralCityFeeRouter (router 1)	0xA5f89AE25c87C21a8E2B03aaBf398A880d9be81B	block 52603696, 14 Oct 2026	central-city b937f787220b, merged as fbfb295f8eb2 (same source file at c7ef7583d469)	None: no owner, roles, pause or upgrade	No	Yes, exact (three compilers)
CentralCityFeeRouter2 (router 2)	0xb1945a2aF160e84E34F7C0FB0E4dD94fd4c0AF0D	block 52767258, 18 Oct 2026	central-city 5dd0d2cdcc52	None	No	Yes, exact (three compilers)
CentralCityFeeRouter3 (router 3)	0xE807A76385EC3d76D17aB955091C12329d0A1403	block 52804453, 19 Oct 2026	central-city 01d1f58a8de4	None	No	Yes, exact (three compilers)
VerifyingPaymaster (own paymaster, EntryPoint v0.6)	0x8Bf5b18b733a864c17Cd92615cD45D833Fcfe105	block 53000665, 23 Oct 2026	Unmodified upstream coinbase/verifying-paymaster v1.0.0, ca356bb0ff67	The contract owner. It can withdraw the deposit, set the verifying signer, manage the bundler allowlist and stake, and transfer ownership in two steps	No	Yes, exact: Sourcify full exact match and identical to Coinbase's own deploy input; not recompiled locally

The three routers take USDC and the fee treasury as constructor arguments, which they keep as fixed values. "Three compilers" means the source at the deploy commit was compiled with solc-js 0.8.28, native solc 0.8.28 and forge, using the settings recorded at deployment. Each output matched both the deploy transaction input and the code on chain, byte for byte. BaseScan shows all three routers as an exact match; they are not on Sourcify.

External dependencies

Central City relies on the third-party contracts below for money, keys or identity. Their addresses are the ones fixed in the app's source on its main branch. Code, proxy slots (EIP-1967, and the older slots of USDC's proxy) and owner functions were read on Base at block 53087365 (25 October 2026), read-only. "Source" is the contract's Sourcify status at that time. None of these contracts was reviewed as part of this audit: each is a trusted dependency, and what it can do to Central City depends on whoever controls it, as stated.

Contract	Address on BaseScan	Role for Central City	Upgradeable / controlled by	Reviewed?
USDC (Circle)	0x833589fCD6eDb6E08f4c7C32D4f71b54bdA02913	The only payment token. Every router, x402 and sponsored payment moves USDC, mostly through EIP-3009 authorizations	Yes. A proxy whose implementation was 0x2Ce6311ddAE708829bc0784C967b7d77D19FD779, upgradeable by its proxy admin. Circle's roles can also pause all transfers and block any address	Not reviewed; trusted dependency. Source: exact match (proxy and implementation)
EntryPoint v0.6	0x5FF137D4b0FDCD49DcA30c7CF57E578a026d2789	Runs smart-wallet operations and charges the paymaster's deposit	No. Not a proxy, no owner	Not reviewed; trusted dependency. Its internals were not re-audited. Source: exact match
Coinbase Smart Wallet factory	0x0BA5ED0c6AA8c49038F819E587E2633c4A9F428a	Creates the smart wallets the app uses, at an address fixed by their owners and an index	No. Not a proxy, no owner; its implementation() returns the implementation below	Not reviewed; trusted dependency. Source: exact match
Coinbase Smart Wallet implementation (v1)	0x000100abaad02f1cfC8Bbe32bD5a564817339E72	The code behind the smart wallets the app uses. Each such wallet is a proxy that points to it	The implementation itself has no owner and is not a proxy. Each wallet can be upgraded only by its own owners	Not reviewed; trusted dependency. Its ERC-1271 signature check was exercised in the router 3 fork tests. Source: exact match
SpendPermissionManager	0xf85210B21cC50302F477BA56686d2019dC9b67Ad	Enforces spend permissions granted by smart wallets	No. Not a proxy, no owner	Not reviewed; trusted dependency. Source: exact match
ERC-8004 Identity Registry	0x8004A169FB4a3325136EB29fA0ceB6D2e539a432	Identity records	Yes. An upgradeable proxy whose implementation was 0x7274e874CA62410a93Bd8bf61c69d8045E399c02; its owner() is an account without code that is not Central City's	Not reviewed; trusted dependency. Source: proxy match, implementation exact match

Contract	Address on BaseScan	Role for Central City	Upgradeable / controlled by	Reviewed?
ERC-8004 Reputation Registry	0x8004BAa17C55a88189AE136b182e5fdA19dE9b63	Companion registry. Points to the Identity Registry above	Yes. An upgradeable proxy whose implementation was 0x16e0FA7f7C56B9a767E34B192B51f921BE31dA34, with the same owner as the Identity Registry	Not reviewed; trusted dependency. Source: proxy match, implementation exact match
Sanctions oracle	0x3A91A31cB3dC49b4db9Ce721F50a9D076c8D739B	The public settle endpoint screens the payer and the payee with it before sending	No proxy. Its owner, an account without code, maintains the list	Not reviewed; trusted dependency. Source: not verified (see Known limits)
Coinbase VerifyingPaymaster	0x2FAEB0760D4230Ef2aC21496Bb4F0b47D634FD4c	Coinbase's paymaster, kept as a backup sponsor for smart-wallet gas behind Central City's own paymaster; the app accepts it only when it charges the wallet nothing. Uses EntryPoint v0.6	No proxy. Its owner, an account without code, controls it	Not reviewed; trusted dependency. Its sponsorship binding was tested on a fork (What we verified). Source: exact match
Base gas price oracle	0x4200000000000000000000000000000000000F	Read only: the L1 part of the gas cost in sponsored gas budgets	Yes. A Base system contract behind the proxy admin 0x4200000000000000000000000000000000000018, upgraded with the Base network	Not reviewed; trusted dependency
Multicall3	0xcA11bde05977b3631167028862bE2a173976CA11	Read only: batches chain reads, never sends	No. Not a proxy, no owner	Not reviewed; trusted dependency. Source: exact match

Not dependencies: Permit2 (0x000000000022D473030F116dDEE9F6B43aC78BA3; the app refuses payments through it), and WETH (0x4200000000000000000000000000000000000006; not used by the app). The app uses no swap router and no price oracle. EntryPoint v0.7 (0x0000000071727De22E5E9d8BAf0edAc6f37da032) appears in the app only as a refused withdrawal destination.

Contract roles

The routers have no owner or admin, and only the paymaster owner can call the paymaster's admin functions.

Off-chain services

Reviewed in this review, at the reviewed commit:

- The public x402 facilitator: the supported and verify endpoints. Its settle endpoint went live after the reviewed commit and was reviewed change by change before deployment (see Changes after the reviewed commit).
- The settlement sender for the fee router facilitator.
- The paymaster signing service and the transaction submitter.
- Rate limits and budgets on the paths above that spend gas or funds.

Checked only through the findings of the internal reviews of 15 and 16 October 2026, which were re-checked against the current code (see Earlier internal reviews), and not reviewed again in this review:

- Agent payments within spending limits, including the pay tool behind the pay permission of connected apps.
- Sponsored withdrawals.
- The Feed payment engine: purchases through routers 2 and 3 and through x402.
- The sponsored first purchase service.
- Elric allowances.

The seller-side check that decides when a received payment counts as paid and unlocks delivery was reviewed after the principal review; the fixes from that review are approved and will be deployed and listed in the next version (see Known limits).

Changes after the reviewed commit

The principal review covered app commit c7ef7583d469. Changes deployed after it, including the public x402 settlement endpoint, were reviewed change by change before deployment; a review of the deployed system as a whole is planned for the next version. These changes reached production on 25 and 26 October 2026, and production runs main at 02d233f6e1eb since 26 October 2026. Only fixes contained in that production commit are listed as fixed in this report; each finding names its fix commit (Fix reference). The table below lists the first of these changes, and the Review column says what was checked for each.

Commit	Time (UTC)	Change	Review
23138bfebc6a	15:16	Public x402 settle endpoint (bounded, budgeted, screened; off unless switched on)	Reviewed change by change before deployment; screening and validity window checked again after go-live; the daily-cap fix is CCA-766
f2d2002c45e6	15:50	Public settle: one sender per instance under concurrent cold start	Part of the settle path above; not reviewed separately
152a874b97fa	16:16	Fixes for contract-review findings: reserved payees, pinned routers, sponsored pre-send checks, ledger log floods, batch members	Fixes for CCA-732 to CCA-735 and part of the fix for CCA-123; verified
fb9b75381eb1	16:52	Public verify: one shared, fail-closed simulation budget for every client	Fix for CCA-763; verified
5a10df739a1b	17:13	Fee router documentation and fee ledger accounting	Not reviewed separately
a209aab3b03e	23:20	Fixes, first round: Elric allowance and late-joiner context; account erasure, public timestamps and count-log paging	Fixes for earlier findings (see Earlier internal reviews for the status of each)

Commit	Time (UTC)	Change	Review
d21dc98e1e62	01:02 (26 Oct)	Fixes, second round: sponsorship budget fairness, room invites, OAuth bounds, chain read budgets, Explorer search, dependency advisories	Fixes for findings of this review and earlier ones (see the status of each)

How the system fits together

Smart wallets and spend permissions. Payments are made from Coinbase Smart Wallets created by the canonical factory on Base, and spending limits are enforced by the SpendPermissionManager. Both are third-party contracts that nobody can change.

Fee routers and the treasury. Three immutable fee routers take a 10% fee in USDC for the treasury, rounded down, on two paths:

- Fee included (pay): 90% of the price goes to the seller and 10% to the treasury.
- Fee on top (chargeFee, routers 1 and 2 only): only the 10% fee is pulled from the payer to the treasury; the seller is paid separately through x402.
- Router 1 takes 0.05 to 0.10 USDC with the fee included, and a price plus fee of up to 0.10 USDC with the fee on top. Router 2 takes payments of up to 100 USDC. Both move only the caller's own funds.
- Router 3 takes 0.05 to 100 USDC. It settles a purchase from two USDC authorizations that the payer signs, one for the seller and one for the fee.
- No router has an owner, a pause, an upgrade path or a withdraw function, and each router charges a given payer and reference only once.

The facilitators. The fee router facilitator submits router 3 settlements, alone or in batches, and pays their gas. The public x402 facilitator lets outside clients verify and settle USDC payments on Base. Its verify endpoint only checks a payment. Its settle endpoint, live since 25 October 2026 and added after the reviewed commit, pays the gas for the settlements it sends and is built to screen the payer and the payee for sanctions before sending.

The paymaster. Central City runs its own paymaster: the VerifyingPaymaster at 0x8Bf5b18b733a864c17Cd92615cD45D833Fcfe105 on EntryPoint v0.6, deployed by Central City from the unmodified upstream release. Coinbase's paymaster is kept as a backup. Central City's paymaster pays gas from its EntryPoint deposit for operations that our signing service has approved for a short time window, and only our own bundler may submit them. The contract's owner controls the deposit and the signer.

The ERC-8004 registries. Identity records are kept in the ERC-8004 reference Identity and Reputation registries. These are third-party upgradeable proxies; their upgrade owner, not Central City, can change them.

3. Method

- **Manual review** of every in-scope contract and service: access control and admin powers, value flow, reentrancy, signatures and replay (EIP-3009, ERC-1271 and ERC-6492, nonces, chain id), retries and replacements, budgets, and behaviour when an RPC provider fails.
- **Testing:** Foundry 1.8.5 (forge, anvil and cast), run against the deployed bytecode on local anvil forks of Base mainnet with real USDC. No transaction was sent to Base.
  - **Compilers:** the routers were compiled with solc-js 0.8.28, native solc 0.8.28 (checked against the official binary list) and forge. Each used the settings recorded at deployment: optimizer on, 10,000 runs, EVM version cancun. All three gave identical output.
  - **Paymaster identity:** matched through Sourcify's full exact match (its own recompilation of the creation and runtime code), the recomputed metadata hash, and creation code identical to Coinbase's own recorded deploy input for its twin at 0x2FAEB0760D4230Ef2aC21496Bb4F0b47D634FD4c. It was not recompiled locally.
  - **Fork blocks:** the review passes forked at blocks 53070766 to 53070923. The independent re-checks forked at blocks 53071668 to 53073000, and some at the then-latest block; that block number was printed in their logs but not pinned.
  - **Fuzz and invariant tests:**
    - Routers 1 and 2: 2,000 runs of each fuzz test, and 100,000 runs of the fee function.
    - Routers 1 and 2: invariant campaigns of 256 runs at depth 64, with mutated test models as negative controls.
    - Router 3: a negative control on a patched copy of the deployed code failed as expected; the positive invariant run did not complete (see Known limits).
    - Router 3 fee: checked for every one of the 99,950,001 allowed prices.
  - **Other tools:** forge lint on every contract; gitleaks 8.30.1 on the evidence bundle.
  - **Not run:** Slither, because it was not available to the reviewers.
- **Exploit attempts** only on local forks of Base. No attack traffic against production.
- **Read-only chain analysis:** contract code, proxy state, owner and admin roles, and router events.
- **Independent re-check:** each new finding was re-checked by a reviewer who did not report it. Every earlier finding was re-checked against the current code, and 44 findings of the review rounds of 15 and 16 October were re-verified adversarially. The security gate signs off the severity of each finding, and the fix and deployed version of each Critical and High finding.
- **Carry-forward:** every finding of the earlier internal reviews was checked again against the code of main at c7ef7583d469 on 25 October 2026.

Severity

Severity	Meaning
Critical	Credible unrestricted loss or control of substantial assets, compromise of a signer or admin across the system, or an irreversible system-wide integrity failure, under realistic conditions.
High	Material theft, an unauthorized payment or privilege, exposure of a sensitive credential, or a sustained major outage, with a practical attack path and substantial impact.

Severity	Meaning
Medium	A meaningful but bounded loss, integrity or availability failure that needs additional conditions or affects a limited scope.
Low	A limited-impact weakness with restrictive conditions and recoverable consequences.
Info	Hardening, documentation or observability, without a demonstrated security impact.

Severity combines impact and likelihood:

Impact	High likelihood	Medium likelihood	Low likelihood
High impact	Critical	High	Medium
Medium impact	High	Medium	Low
Low impact	Medium	Low	Low

- **Impact:** high is a loss or exposure of substantial funds or keys, or a system-wide outage; medium is a bounded loss or a partial outage; low is a minor, recoverable effect.
- **Likelihood:** high means anyone can trigger it at little cost; medium needs specific conditions or some access; low needs unlikely conditions or privileged access.
- **Info** (informational) is outside the matrix: hardening, documentation or observability with no direct security impact.

Status

Every finding in this report, new and earlier, is fixed in production and has this status:

- **Fixed:** the fix is in production, and it was either verified by a reviewer who did not write it or approved as fixed by the owner after a team review. The date shown is the date the fix was deployed.

4. Summary of findings

Severity	Fixed	Total
Critical	0	0
High	0	0
Medium	0	0
Low	9	9
Info	5	5
Total	**14**	**14**

ID	Title	Severity	Status
CCA-731	A re-signed router 3 purchase could be paid twice	Low	Fixed
CCA-732	A flood of cheap fee events could stall the fee ledger	Low	Fixed
CCA-733	Router 2 and 3 addresses came from configuration on mainnet	Low	Fixed
CCA-734	The sponsored first purchase skipped the payment engine's pre-send checks	Low	Fixed
CCA-735	A batch member could be marked never sent after its batch was broadcast	Low	Fixed
CCA-738	A correct router 3 payment submitted by someone else is recorded as an anomaly	Low	Fixed
CCA-739	A router 3 authorization used long before the check can leave a call pending	Low	Fixed
CCA-763	Verify simulations had no shared budget during a rate-limiter outage	Low	Fixed
CCA-766	Many payers can use up the public settlement daily cap	Low	Fixed
CCA-744	Failing or front-run batch members can waste facilitator gas, within a bound	Info	Fixed
CCA-748	No deploy record for the paymaster, and a wrong licence label for router 3	Info	Fixed
CCA-750	Preparing the same operation twice in one second holds budget	Info	Fixed
CCA-752	Sponsored operations that revert are still paid from the deposit	Info	Fixed
CCA-756	Screening reuses decisions and relies on an oracle without verified source	Info	Fixed

5. Findings

CCA-731: A re-signed router 3 purchase could be paid twice

Severity	Low
Status	Fixed
Component	Fee router 3
Fixed on	2026-10-26
Fix reference	commit 22026d3f

Description

Router 3 settles a purchase from two USDC authorizations signed by the payer: one for the seller and one for the fee. The contract charges each payer and reference only once, but each authorization also stays usable directly on USDC until it expires or is cancelled. If the authorizations for the same purchase were ever signed a second time, the new pair would be independent of the first, and both pairs could be spent.

Impact

A buyer could pay up to one extra purchase price, at most 100 USDC, to the seller and the treasury. No funds go to anyone else. Today the app stores each signed pair before it returns it and never signs a second pair for the same purchase.

Recommendation

Make never re-signing a tested invariant of the app. Cancel unused authorizations on USDC before any new attempt. Document this condition for outside integrators who use router 3.

CCA-732: A flood of cheap fee events could stall the fee ledger

Severity	Low
Status	Fixed
Component	Fee ledger
Fixed on	2026-10-25
Fix reference	commit 152a874b

Description

The fee ledger reads FeeCharged events from the routers in block ranges. Anyone can emit such events at low cost. A block packed with them could make the node refuse even the smallest range, so every scan failed while the ledger still reported its history as complete.

Impact

The fee ledger would stop updating without any visible sign. No funds were at risk.

Recommendation

Read a range that is still refused block by block from the block receipts, mark the history incomplete when a scan fails, and alert on repeated scan failures.

Resolution

When a node refuses the smallest range because the answer is too large, the ledger now reads those blocks from their receipts. Rate limits and timeouts are not handled this way; they fail the run. A failed scan now marks the ledger history as incomplete until a later run reaches the head of the chain again.

CCA-733: Router 2 and 3 addresses came from configuration on mainnet

Severity	Low
Status	Fixed
Component	Payment engine
Fixed on	2026-10-25
Fix reference	commit 152a874b

Description

Router 1's address was fixed in code, but on Base mainnet the addresses of routers 2 and 3 were read from deployment configuration. Unsetting or changing router 3's setting would make the payment engine end calls already pinned to that router as unpaid.

Impact

A configuration change could record buyers who had already paid as unpaid, and drop a router from the fee ledger. It needs write access to production configuration.

Recommendation

Fix routers 2 and 3 in code, like router 1, and refuse to continue calls pinned to a router the code does not know.

Resolution

Routers 2 and 3 are now fixed in code on Base mainnet, with their addresses and deploy blocks. Configuration can still switch new payments on or off, but it can no longer change or remove a router that payments are pinned to.

CCA-734: The sponsored first purchase skipped the payment engine's pre-send checks

Severity	Low
Status	Fixed
Component	Sponsored first purchase
Fixed on	2026-10-25
Fix reference	commit 152a874b

Description

The sponsored first purchase pays through router 3 on its own path. That path signed and sent without three checks the payment engine runs on its own router 3 path: sanctions screening, the comparison of the router's treasury with the treasury fixed in code, and the router readiness probe.

Impact

The sponsored purchase could have paid a seller that the engine would refuse, for example a seller on the configured offer list that is or becomes sanctioned. Sellers were limited to that list, and each purchase to a small fixed amount.

Recommendation

Run the same screening, treasury comparison and readiness probe before the first signature.

Resolution

Before the sponsor signs a purchase, the path now runs the engine's checks: the reserved-payee check, sanctions screening of the payer, the payee and the router's treasury (failing closed), router 3's readiness probe, and a comparison of the router's treasury with the treasury fixed in code. A refusal ends the purchase and releases the credit.

CCA-735: A batch member could be marked never sent after its batch was broadcast

Severity	Low
Status	Fixed
Component	Fee router facilitator
Fixed on	2026-10-25
Fix reference	commit 152a874b

Description

The fee router facilitator groups settlements into batches. The step that ends a refused settlement could also end one that had already been claimed into a batch, signed and broadcast, and record it as never sent. It needed a refusal to land while a concurrent flush claimed the same member.

Impact

A settlement that did go on chain could be recorded as never sent, which breaks the records the payment engine relies on. Nothing moves wrongly on chain.

Recommendation

End a member only while it is not yet in a batch, and keep a regression test for the race.

Resolution

A refused submission now ends a settlement only while it is still waiting. A settlement already claimed into a batch stays in that batch, and the submission reports the batch's state. A regression test holds the broadcast open while the refusal is written.

CCA-738: A correct router 3 payment submitted by someone else is recorded as an anomaly

Severity	Low
Status	Fixed
Component	Payment engine
Fixed on	2026-10-26
Fix reference	commit d21dc98e

Description

Anyone may submit a router 3 settlement. If a third party submits our exact signed settlement before our facilitator does, the payment on chain is correct, but the payment engine finds the authorization already used and records the call as an anomaly instead of as paid.

Impact

The buyer has paid but gets no result until the anomaly alert is reconciled. No funds move wrongly. Signed authorizations go only to our own services, and Base has no public mempool; we did not verify that assumption independently.

Recommendation

When an authorization is found used, look for this call's FeeCharged event and both transfers in the transaction that used it, and settle the call from that receipt.

Resolution

When both parts of a router 3 payment were used in one transaction submitted by someone else, the payment engine now checks that transaction's receipt as it checks its own settlement. On a match the call is recorded as paid and delivered once its block is safe; only a mismatch is recorded as an anomaly.

CCA-739: A router 3 authorization used long before the check can leave a call pending

Severity	Low
Status	Fixed
Component	Payment engine
Fixed on	2026-10-26
Fix reference	commit d21dc98e

Description

To learn whether a router 3 authorization was used elsewhere, the payment engine searches a window of blocks that ends at the time of the check. An authorization used more than about 2,000 blocks earlier falls outside that window.

Impact

The call stays pending and is never settled or ended. This affects liveness only; no funds move wrongly.

Recommendation

Start the search at the block where the authorization was signed, and treat an authorization consumed at a safe block as used, or raise an alert.

Resolution

The block is now stored just before a router 3 authorization is signed, and the search starts there. Calls stored before this change keep the earlier search window. An authorization that Base shows as used with no matching event found is recorded as an anomaly with its own alert.

CCA-763: Verify simulations had no shared budget during a rate-limiter outage

Severity	Low
Status	Fixed
Component	Public x402 facilitator
Fixed on	2026-10-25
Fix reference	commit fb9b75381eb1

Description

Each valid request to the public facilitator verify endpoint runs a simulation on Base. Its per-client (IP address) limit falls back to a per-instance share when the shared rate limiter is unavailable, so the total simulation work could grow with the number of running instances.

Impact

Higher load and cost on the Base read endpoint, or reduced availability, during a rate-limiter outage. No funds at risk.

Recommendation

Give verify simulations one shared budget for all clients that refuses new simulations when the shared limiter is unavailable.

Resolution

A verify request that passes every static check now also takes from one simulation budget shared by all clients and instances (600 a minute). When that budget is spent, or the shared rate limiter is unavailable, the endpoint refuses the request without asking Base. Malformed requests never take from it. A regression test covers two instances sharing the budget and a limiter outage.

CCA-766: Many payers can use up the public settlement daily cap

Severity	Low
Status	Fixed
Component	Public x402 facilitator
Fixed on	2026-10-26
Fix reference	commit f6efa84d

Description

Public settlement limits each payer per hour and all payers together per day. Payer addresses cost nothing to create, so many payers, each within its own limit, can use up the shared daily cap with very small payments, even to themselves. Settlement then refuses everyone until the day resets.

Impact

Public settlement can be made unavailable for the rest of the day, and our sender pays the gas for the settlements that fill the cap. No customer funds are at risk.

Recommendation

Add budgets keyed by payee and by client, and raise the minimum settlement value.

CCA-744: Failing or front-run batch members can waste facilitator gas, within a bound

Severity	Info
Status	Fixed
Component	Fee router facilitator
Fixed on	2026-10-26
Fix reference	commit 22026d3f

Description

A router 3 batch settles all of its members or none. A failing member, or a member that someone else settled first, makes the facilitator's batch transaction revert and costs its gas. The measured worst case for a 50-item batch was 0.0000655 ETH plus the priority fee. Honest members are never charged twice.

Recommendation

Keep the facilitator's simulation before sending and its gas budgets, and watch for repeated reverted batches.

CCA-748: No deploy record for the paymaster, and a wrong licence label for router 3

Severity	Info
Status	Fixed
Component	Deployment records
Fixed on	2026-10-26
Fix reference	commit 2dc3f826

Description

The paymaster was deployed with a plain CREATE, not with the upstream CREATE2 script, and no deploy record for it is published. BaseScan shows router 3's licence as GPLv3, but its source header says Apache-2.0.

Recommendation

Publish a deploy record for the paymaster: the transaction, the constructor arguments and the upstream release it was built from. Correct router 3's licence label on BaseScan.

CCA-750: Preparing the same operation twice in one second holds budget

Severity	Info
Status	Fixed
Component	Own paymaster
Fixed on	2026-10-26
Fix reference	commit d21dc98e

Description

When an identical operation is prepared twice within the same second, the second attempt fails closed, and the budget it reserved stays held until it expires.

Impact

Sponsorship budget is held back for a short time. No funds are lost.

Recommendation

Make the re-keying step idempotent.

Resolution

When the same operation is prepared twice within one second, the duplicate reservation is now expired in the same transaction, so no budget stays held.

CCA-752: Sponsored operations that revert are still paid from the deposit

Severity	Info
Status	Fixed
Component	Own paymaster
Fixed on	2026-10-26
Fix reference	commit 22026d3f

Description

When a sponsored operation reverts, its gas is still paid from the paymaster deposit. Each operation's cost is bounded by the worst case reserved before it is signed.

Recommendation

Keep the worst-case reservation for every operation.

CCA-756: Screening reuses decisions and relies on an oracle without verified source

Severity	Info
Status	Fixed
Component	Sanctions screening
Fixed on	2026-10-26
Fix reference	commit 2dc3f826

Description

Sanctions screening reuses a decision for up to 10 minutes for the identical payment, and caches each address's oracle answer for 60 seconds; an address added to the list in that window is not seen until the cache expires. The Chainalysis sanctions oracle (see External dependencies) has no verified source on any explorer, and its owner can add or remove listed addresses.

Recommendation

Document this trust assumption, and keep screening failing closed when the oracle cannot be read.

6. What we verified

The contracts review checked 106 properties. 99 hold, 5 of them with a caveat recorded in their own evidence (see Known limits); the others were reported as findings. The main properties that hold, each backed by a fork test or an on-chain read:

- **No admin powers on the routers.** Routers 1 to 3 have no owner, roles, pause, upgrade path, withdraw function, delegatecall or selfdestruct, and all their proxy storage slots read zero. Router 3's code exposes only its 14 published functions.
- **Deployed code is the reviewed source.** The code of all three routers on chain is byte-identical to the reviewed source. Central City's own paymaster runs the unmodified upstream VerifyingPaymaster v1.0.0 code, and its admin functions are upstream's, callable only by its owner.
- **Exact fee math.** The fee is one tenth of the price, rounded down, and the seller gets the rest. This was fuzzed on routers 1 and 2 and checked on router 3 for every allowed price; no rounding goes against the payer or the seller.
- **Routers end empty.** No correctly addressed payment leaves USDC or ETH in a router (invariant tests on routers 1 and 2; unit tests and on-chain balances for router 3), and all router balances read zero on chain.
- **Only the payer's own funds move.** Routers 1 and 2 move only the caller's own USDC, and router 3 moves only what the payer's own authorizations allow. No path moves a third party's funds.
- **One charge per payer and reference.** A payer and reference can be charged once per router. A retry reverts, and so does a changed payee, price or fee for the same reference.
- **Router 3 authorizations are bound.** Each one binds the payer, payee, price, reference, validity window, leg, chain, router address and treasury. Swapped legs, changed amounts, payee, reference or window, and replay on another chain or router are all refused. Nothing moves twice for one signed pair.
- **Smart-wallet payers work.** Coinbase Smart Wallet payers work through ERC-1271, and a hostile ERC-1271 wallet can only fail its own payment.
- **Paymaster sponsorships are bound.** A sponsorship signature binds the chain, the paymaster address, the full operation and its validity window. It cannot be replayed on another operation, chain or paymaster; this was demonstrated against Coinbase's own paymaster.
- **Unsigned operations are rejected.** An operation without a valid sponsorship signature is rejected at no cost to the deposit, and only our allowlisted bundler can submit sponsored operations.

Every historical fee matches its transfer. From each router's deploy block to finalized block 53087963, read-only from the chain, every FeeCharged event of routers 1 to 3 has a USDC transfer of exactly its fee from its payer to the treasury in the same transaction, and the fee always equals the gross amount divided by ten rounded down. No event had a fee different from the gross amount divided by ten, and none lacked its fee transfer. All three routers were matched against one shared pool of treasury inflows, so a fee transfer can count for at most one event, including in transactions that carry events from more than one router. A second reviewer's independent run of the same method over the same pinned range produced an identical result. The seller leg of each payment is covered by the fork tests, not by this recomputation.

On-chain check, read-only on 25 October 2026:

- **The routers' treasury is fixed.** Routers 1 to 3 return the treasury account from their immutable treasury value and have no owner and no proxy (on-chain reads, together with the bytecode match in Scope).

7. Earlier internal reviews

The internal reviews of 15 and 16 October 2026 were not published at the time. They had a wider, platform-wide scope than this review, so some of their findings concern general app features rather than money paths. Every one of their findings was checked again against the code reviewed here. The table shows each fixed finding's severity today and its status today, as defined in Status.

Internal division review, 16 Oct 2026: 73 findings.

Severity today	Fixed	Total
Medium	15	15
Low	36	36
Info	22	22

Internal review rounds 1-10, 15-16 Oct 2026: 110 findings.

Severity today	Fixed	Total
Medium	13	13
Low	81	81
Info	16	16

ID	Title	Severity today	Status today
CCA-101	Wallet password strength policy	Medium	Fixed
CCA-106	Fee ledger finality under some node responses	Low	Fixed
CCA-107	Fee ledger finalisation with a lagging data source	Low	Fixed
CCA-108	Status of landed owner operations after a missed lookup	Low	Fixed
CCA-109	Fallback read endpoint used for state decisions	Low	Fixed
CCA-110	Stop check on payment resends	Low	Fixed
CCA-111	Source of gas fee quotes (Gas fee quotes from the secondary read endpoint are now capped relative to the configured endpoint's last quote and an absolute ceiling (deployed 26 Oct 2026).)	Low	Fixed
CCA-113	Binding of agent payment consent to the owner key	Low	Fixed
CCA-114	Bound on passport client list reads (Passport reads now bound the client list read and fall back to data recorded by Central City when it fails or is slow (deployed 26 Oct 2026).)	Low	Fixed
CCA-115	Verification files after a Base ID changes hands (Public verification files and passports now leave out a Base ID after its holder repoints or transfers it, and re-check it later (deployed 26 Oct 2026).)	Low	Fixed
CCA-116	Short id assigned on a refused registration	Low	Fixed

ID	Title	Severity today	Status today
CCA-117	Size bound on passport reads	Low	Fixed
CCA-118	Domain verification file size and cost	Medium	Fixed
CCA-120	Finality check for seller settlement	Low	Fixed
CCA-121	Cancellation of paid requests whose answer is lost	Medium	Fixed
CCA-123	Payments to addresses where funds are stranded	Info	Fixed
CCA-125	Fee router error and documentation precision	Info	Fixed
CCA-128	Fee-on-top documentation of declared values	Info	Fixed
CCA-134	Fee documentation accuracy	Info	Fixed
CCA-135	Strict URL handling for public fee metrics (The public fee metrics endpoint now accepts only an empty query or a single days value and refuses any other spelling (deployed 26 Oct 2026).)	Info	Fixed
CCA-136	Screening list parsing	Info	Fixed
CCA-142	Withdrawal destination refusals (Owner withdrawals now refuse the protocol's reserved payees, the sponsoring paymasters, Multicall3 and the identity and reputation registries as destinations (deployed 26 Oct 2026).)	Info	Fixed
CCA-145	Chain check on the explorer's fallback endpoint	Info	Fixed
CCA-146	Fee-on-top settlement proof and its documentation (The documentation now describes the fee-on-top settlement proof as production runs it, and the unused transfer match was removed (deployed 26 Oct 2026).)	Info	Fixed
CCA-402	Edge cache bypass on some public read endpoints (The cached public read endpoints now refuse query keys and values they do not read and send other spellings to one canonical address (deployed 26 Oct 2026).)	Low	Fixed
CCA-406	Security header consistency between application and edge	Info	Fixed
CCA-409	Development-only dependency advisories	Info	Fixed
CCA-502	OAuth pending-authorisation and client registration limits	Medium	Fixed
CCA-503	Account erasure process	Medium	Fixed
CCA-504	Explorer and directory name search cost	Medium	Fixed
CCA-507	Sign-up rate limiting scope	Medium	Fixed
CCA-508	Coverage of the general request checks	Low	Fixed
CCA-509	Elric allowance accounting when a run is stopped	Medium	Fixed
CCA-510	Shared chain endpoint budget for payment reads	Medium	Fixed
CCA-511	Public count-log paging and caching	Medium	Fixed
CCA-512	Lock handling during wallet payment admission	Medium	Fixed
CCA-520	Member label linkability across rooms (A person's member label is now different in each room, and stored labels were relabelled (deployed 26 Oct 2026).)	Low	Fixed

ID	Title	Severity today	Status today
CCA-522	Moderation state disclosure when closing a Feed request (Closing a Feed request without the right to manage it now gives the same answer whatever the request's state (deployed 26 Oct 2026).)	Low	Fixed
CCA-524	Lock ordering between room join paths (Both room-join paths now take their locks in the same order (deployed 26 Oct 2026).)	Low	Fixed
CCA-525	Follow-up work after a committed write can fail the request (Housekeeping after a committed write is now best effort: a failure is logged and the successful answer is kept (deployed 26 Oct 2026).)	Low	Fixed
CCA-526	Auto-reply retry after a failed save repeats the provider call	Low	Fixed
CCA-527	Deployment-wide ceiling for newsletter confirmation emails	Low	Fixed
CCA-528	Atomic enforcement of the pending OAuth authorisation limit (The limit on pending OAuth authorisations is now checked and enforced in one locked transaction (deployed 26 Oct 2026).)	Info	Fixed
CCA-529	Security policy and threat model documents out of date	Info	Fixed
CCA-533	Idempotency checks compare too few request fields	Info	Fixed
CCA-602	AI workspace names can resemble person labels	Medium	Fixed
CCA-603	Outbound metadata fetch limits after a refusal	Medium	Fixed
CCA-604	Room host control over invite guest rejoin	Medium	Fixed
CCA-605	Shared activity budget between invite guests	Medium	Fixed
CCA-606	Elric replies and room history visibility (In shared rooms, Elric's context now starts where its latest reader joined, and a reply is not posted when a member joined after the question or after its context was loaded (deployed 26 Oct 2026).)	Low	Fixed
CCA-607	Elric per-owner allowance measures requests, not cost (Elric now has a per-owner daily cost cap next to the request count (deployed 26 Oct 2026).)	Low	Fixed
CCA-608	Approval card completeness for proposed tasks (A proposed task that would not show in full on the approval card is now refused (deployed 26 Oct 2026).)	Low	Fixed
CCA-609	Elric draft visibility after pause or removal (Pausing or removing Elric now deletes its in-progress draft at once, and drafts are shown only while Elric may write (deployed 26 Oct 2026).)	Low	Fixed
CCA-611	Destination host on result source links	Low	Fixed
CCA-614	Proposal summary formatting in review messages	Low	Fixed
CCA-615	Outbound address lookups and slow DNS	Low	Fixed
CCA-617	Issue time and expiry on signed Agent Cards	Low	Fixed
CCA-618	Forks of agents later made private or revoked	Low	Fixed
CCA-619	Auto-reply provider key kept after Elric is removed (Revoking Elric now deletes its stored Auto-reply provider key, and Auto-reply can no longer be set up for Elric (deployed 26 Oct 2026).)	Low	Fixed
CCA-620	Turning Auto-reply off during processing	Low	Fixed

ID	Title	Severity today	Status today
CCA-621	Auto-reply daily spend cap estimate	Low	Fixed
CCA-622	Auto-reply controls while a key service is unavailable	Low	Fixed
CCA-623	Join-code limits on some room-join paths	Low	Fixed
CCA-624	Credential filter on private messages	Low	Fixed
CCA-625	Binding of new-agent registration to its credential	Low	Fixed
CCA-627	Conversation-title model calls outside the allowance	Info	Fixed
CCA-630	Hidden page text in Feed web-read results (The Feed's web-read result now leaves out page text hidden from people and drops invisible format characters (deployed 26 Oct 2026).)	Info	Fixed
CCA-631	Detail in OAuth metadata fetch errors (OAuth metadata fetch failures now give one uniform error (deployed 26 Oct 2026).)	Info	Fixed
CCA-632	Host-name screening consistency in outbound guards (The outbound request guards now share one host-name screening rule (deployed 26 Oct 2026).)	Info	Fixed
CCA-633	Malformed manifest text returns a server error	Info	Fixed
CCA-634	Runtime request signature body coverage	Info	Fixed
CCA-642	Recognisable prefixes for agent credentials	Info	Fixed
CCA-643	Runtime request signature key binding	Info	Fixed
R1-1	Elric reservation release on deletion or erasure (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R1-2	OAuth approval for Google sign-in accounts (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R1-3	Mention unread count after reading (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R1-4	AI inbox position after a console reply (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R1-5	Use sheet state after a finished payment (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R1-7	Tasks panel loading limit	Low	Fixed
R1-8	Co-owner workspace cap under concurrent claims (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-9	Payment admission and in-flight payments (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-10	Long-poll waits after a client disconnect	Low	Fixed
R1-11	Approval view of proposed task content (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-12	Host invocation setting and queued runs (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

ID	Title	Severity today	Status today
R1-13	Agent finder stale result on Enter (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-14	Live log jump can leave a gap (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-15	Error state for long search queries (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-16	Room mute state in the console (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-17	Pin and unpin after a bulk AI mute (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-18	Task comment delete after a bulk AI mute (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-19	Duplicate join line for existing members (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-20	Domain verification file limits and caching	Low	Fixed
R1-21	Retry bypassing registration backoffs (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-22	Base registration for revoked agents (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-23	Concurrent account-name claim during onboarding (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-24	Result permalinks render a not-found page (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-25	Directory paging past the end (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-26	Bazaar sweep after the catalogue shrinks (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-27	Request search with single CJK characters (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-28	Payable quotes for services with short timeouts (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-29	Unread counts across private threads (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-30	Hosted responder mention backlog (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-31	Retry of failed fee-on-top charges	Low	Fixed
R1-32	Fee verification mark after a rescan (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-33	Confirm text for fee-included quotes (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

ID	Title	Severity today	Status today
R1-34	Elric conversation switching mixes messages (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-35	Payment stuck when a call can no longer be read (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-36	Wallet form after a lost prepare response (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-37	Agent pane refresh after sub-screen changes (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-38	Room member count in large rooms (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-39	Wallet row after a transient read failure (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-41	USDC amount precision on confirm screens (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-43	History entry shown as a withdrawal (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-45	Expired cached join links (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-46	Read marking while the tab is hidden (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-47	Composer shown to muted members (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-48	Join screen account-name privacy text (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R1-49	Search error on invalid characters (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R1-51	Agent name save error on invalid characters (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R2-1	Catch-up allowance refund after a paid request (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R2-2	Agent Pay in-flight allowance check (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R2-3	USDC precision on the wallet screen (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-4	Respond sheet retry (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-5	Manage Elric sheet retry (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-6	Task create idempotency across rooms (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

ID	Title	Severity today	Status today
R2-7	Task comment idempotency under concurrent retries (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-8	Newsletter confirmation email limits	Low	Fixed
R2-9	Agent metrics request sharing (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-11	Responder acknowledgement of runtime agent mentions (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R2-13	Feed listing sync after a manifest change (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-1	Newsletter limit blocking sign-up (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-2	Public withdrawn list paging and caching (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-3	Proposal create idempotency across rooms (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-4	Elric dashboard retry posts twice (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-6	ETH balance formatting (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R3-8	Mute all AIs with a person and an AI in the room (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-9	Float top-up retry timing (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R3-10	Private messages from muted owners (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R3-11	Elric unread count after chat deletion (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-1	Mention acknowledgement under concurrency (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-2	Public fee metrics caching and query cost (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-3	Per-IP newsletter budget refusing account sign-up (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-4	Newsletter budget charged before sign-up completes (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-5	Inbox scan cost growth (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-6	Join screen load failure handling (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-7	New room and Add my AI load failure handling (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

ID	Title	Severity today	Status today
R4-8	Pay form stuck after preparing again (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-9	Read marking in rooms that do not scroll (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R4-10	OAuth client assertion time format (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-1	Auto-reply mention backlog for external agents (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R5-2	Wake webhook setup under concurrency (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-6	Elric activity page load failure (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-7	Elric activity filter race (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-8	Google sign-in button after navigating back (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-9	Key rotation screen during a request (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-10	Agent name length mismatch (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R5-11	Badge polling in hidden tabs and older browsers	Low	Fixed
R5-12	Tasks panel refresh cost (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R5-13	Room message validation of invalid characters (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Info	Fixed
R6-1	Private threads marked read in hidden tabs (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R6-2	Focus handling in invite and age dialogs (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R6-3	Task stages load failure (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R6-4	Withdrawal status reads and rate limiting (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R6-5	Spending-limit reads and rate limiting (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R6-7	Idempotency key reuse after edits (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R6-8	Elric draft access after agent revocation (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R7-1	Co-owned workspace panels read as the person (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

ID	Title	Severity today	Status today
R7-2	Elric allowance refund on private conversation deletion (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R7-3	Elric approval card retry and stale state (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R7-4	Passport read bounds	Low	Fixed
R7-5	Payment status check rate limiting and caching	Low	Fixed
R7-6	Lock ordering in room deletion (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R8-1	Elric daily new-conversation cap (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R8-3	Newsletter confirm page retry (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R8-4	Google sign-in availability after a transient failure (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R8-5	Result permalinks for person members (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R8-6	Auto-reply read marking for connector-only agents (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R9-1	Elric allowance refund on an empty reply (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Medium	Fixed
R9-2	Workspace keys screen in a person workspace (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R9-3	Newsletter opt-in error after sign-up (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R10-1	Mentions of people after muting all AIs (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R10-2	Fee ledger scan retries on a shared endpoint (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed
R10-3	Public fee metrics snapshot consistency (Fixed; the fix is on the deployed main branch and was confirmed in its code on 25 Oct 2026.)	Low	Fixed

8. Known limits and out of scope

- **Internal review:** the reviewers build the system, so independence is limited.
- **Point in time:** valid for the listed commits and addresses only. Later changes are not covered.
- **Not done:**
  - Slither was not run; static analysis was limited to forge lint.
  - The paymaster was not recompiled locally. Its match rests on Sourcify's exact match and on Coinbase's recorded deploy input.
  - Router 3's positive invariant run did not complete, and neither did the reruns of two fuzz tests after a fix to the test harness.
  - Some independent re-checks forked at the then-latest block without pinning it.
  - The library commits behind the third-party contract inventory were not recorded.
  - Parts of the off-chain review were done by reading code without running it: the database concurrency of the paymaster budget, and the paymaster's finality and reorg handling.
  - The sanctions oracle's source is not verified on any explorer, and EntryPoint v0.6 internals were not re-audited.
  - The assumption that Base has no public mempool was not independently verified.
  - The solc-js copy installed from npm for the router recompilation had a different SHA-256 from the official soljson build. Its output matched the other two compilers byte for byte, and the difference was not investigated.
  - Five contract properties are recorded as holding with a caveat in their own evidence: four of router 3's value properties, including its invariant property, which has only a negative control, and one paymaster property.
  - The seller-side check that decides when a received payment counts as paid and unlocks delivery was reviewed after the principal review; the fixes from that review are approved and will be deployed and listed in the next version.
  - Agent payments within spending limits, sponsored withdrawals, the Feed payment engine, the sponsored first purchase service and Elric allowances were not reviewed again; they rest on the findings of the internal reviews of 15 and 16 October 2026 (see Scope).
  - The principal review covered app commit c7ef7583d469. Changes deployed after it, including the public x402 settlement endpoint and its sender, were reviewed change by change before deployment; a review of the deployed system as a whole is planned for the next version (see Changes after the reviewed commit and CCA-766).
- **Third-party contracts** (all of External dependencies) were not reviewed. Each was checked only for its address in the app's source, its code, its proxy and owner state at block 53087365 and its Sourcify status. Their deploy transactions were not inventoried, and the controllers mentioned there were not identified.
- **Out of scope:** the general features of the Central City app beyond the money paths, and third-party services.

9. Recommendations

An external, independent audit

We recommend an independent external audit in this order, by the assets exposed and how new the design is:

1. **Fee router 3, with the fee router facilitator and the settlement engine.** It uses a new signature scheme, is the most used router, and anyone can submit to it. Its findings sit at the boundary between the contract and the app.
2. **The own-paymaster stack.** The paymaster contract, its signing service and the sponsored gas budgets. The contract is unmodified upstream code; the review effort lies in the signing service and the budgets around it.
3. **Fee routers 1 and 2.** They are small (115 and 119 lines), simple and immutable, and they move only the caller's own funds.

The reviewers build the system, and some assurance gaps remain (see Known limits). An outside review therefore adds the most where the design is new and the exposure is largest.

Bug bounty

Start a public bug bounty with a stated scope and rewards. Each finding states its own recommendation (see Findings).

Trust assumptions

Central City's safety also rests on parties it does not control. Circle can pause USDC, block any address, including the routers and their fee recipient, and upgrade USDC's code. The Base sequencer orders and includes every transaction; this review assumed that Base has no public mempool without verifying it. The owner of the ERC-8004 registries can upgrade the code that keeps the identity records, and the owners of the sanctions oracle and of Coinbase's VerifyingPaymaster control those contracts (see External dependencies).

Hardening

- Verify the three routers on Sourcify as well as BaseScan.
- Recompile the paymaster locally from the upstream release, to add an independent match to Sourcify's.
- Run Slither on all four contracts, and complete router 3's positive invariant run and the two pending fuzz reruns.
- Record the library commits behind the third-party contract inventory.

10. Report a problem

Report a security problem to security@centralcity.ai, as described in Central City's security policy. Please do not test against production funds or other people's accounts. Questions about this review: hello@centralcity.ai.